GENX / ClinPGx CDSS
Auditoria técnica consolidada

16 de outubro de 2026 | Avaliação somente leitura | GitHub + Vercel + Supabase + análise normativa e científica

Veredito executivo: o protótipo demonstra integração operacional documentada e publicada; NÃO está comprovadamente apto ao uso clínico real. Os resultados de integração relatados pelo REA são compatíveis com a arquitetura observada, mas paridade funcional, validade clínica, conformidade LGPD/HIPAA e regularização SaMD não estão demonstradas por evidência suficiente.

Eixo	Classificação	Motivo decisivo
Infraestrutura	FUNCIONAL / sujeito a validação	Vercel READY; GitHub integrado; tabelas Supabase fechadas; REA informou HTTP 200/cache hit.
Segurança para dados reais	NÃO APROVADO	Acesso público condicionado a cabeçalhos falsificáveis; ausência de identidade e governança de pacientes.
Exatidão clínica	NÃO APROVADO	Fallback não equivalente; alelos desconhecidos interpretados como normais; comedicações ignoradas online.
Interoperabilidade FHIR	NÃO CONFORME como declarado	Bundle transaction sem entry.request; não há serviço CDS Hooks completo.
Regulatório e licenças	INDETERMINADO / RISCO ALTO	RDC 657/2022, 751/2022, LGPD, políticas ClinPGx e possível CFM IA requerem avaliação formal.

Recomendação de liberação: GO somente para demonstração com dados estritamente fictícios e identificada como protótipo não validado. NO-GO para pacientes reais, prescrição orientada pelo software, alegações de certificação e comercialização clínica antes da resolução dos bloqueios P0/P1.

Critério probatório: "demonstrado" = identificado no código/metadados/SQL; "relatado" = teste informado pelo REA sem log bruto e artefato de verificação independente; "não demonstrado" = documentação inconclusiva; "inferência" = risco derivado da arquitetura.

1. Escopo, fontes e método

Escopo examinado em leitura: branch main de boiverde/genx, HTML principal (~1.944 linhas), API /api/gsi, scripts/test_scenarios.js, README, vercel.json, relatórios REA, versões HTML dos dois dossiês publicados ao lado de seus PDFs, metadados da Vercel e RLS/privilegios/advisors do Supabase. Não foram executados testes com pacientes reais nem alterações de código, banco ou configuração nesta fase.

Os dois PDFs foram localizados via GitHub; a leitura crítica de seu conteúdo textual utilizou as versões HTML oficiais no mesmo diretório. Não foi feita comparação binária/visual de paginação entre PDF e HTML. Consultaram-se normas e fontes públicas oficiais (Anvisa, ANPD, HHS, CFM, CPIC/NCBI, HL7 e ClinPGx).

Estado verificado: Vercel produção READY, commit 0552a512..., função na região iad1 (EUA); Supabase GENX na região sa-east-1 (Brasil). A infraestrutura repassa genótipos ao serviço ClinPGx fora do banco local. A conformidade de cada transferência não foi comprovada.

2. Arquitetura e fluxo de dados

Fluxo atual: navegador → interface HTML com perfil/comedicações em memória e localStorage → POST relativo /api/gsi com genotypes e sources (sem comedications) → controle por Origin/Referer ou Bearer → RPC Postgres de quota de cliente → busca gsi_cache → no miss, quota global e POST para api.clinpgx.org → grava genotype_payload e response_payload no Supabase com expires_at+24h → devolve JSON para renderização com innerHTML. Em falha, frontend usa recomendações locais predefinidas.

Persistência: patients possui 3 registros simulados mas não está conectado ao frontend. O navegador usa objeto SAVED_PATIENTS em memória. O botão de salvar modifica esse objeto apenas nesta sessão; localStorage guarda o perfil ativo, não toda a carteira de pacientes.

Limites: a rota usa limitador distribuído de 30 consultas/minuto por hash de IP e 1 nova ida à API por segundo. O hash da chave do cache não anonima genotype_payload, que é gravado em JSON claro no armazenamento lógico do aplicativo. Respostas expiradas deixam de ser servidas, mas não são purgadas automaticamente.

3. Achados críticos e prioritários

F01 — Alelos desconhecidos viram atividade normal [P0 / clínico]

Constatação: Em prototype-clinpgx.html, linhas ~1108–1112: scores[a] ausente retorna 1.0. Só cinco genes possuem tabelas específicas, embora 25 sejam oferecidos. Um CYP2C19 *4 pode ser interpretado como normal no fallback; a regra CYP2C19 também testa perda de função só para *2/*3.

Ação: Desabilitar recomendações clínicas quando alelo/fenótipo não for resolvido pela tabela versionada da diretriz. Tratar como desconhecido/sem laudo; testar variações raras e no-function.

F02 — Motor offline clínico incompleto [P0 / clínico]

Constatação: runLocalFallbackEngine gera regras locais para codeína, tramadol, clopidogrel, sinvastatina e fluorouracil. No modo offline, o restante do catálogo desaparece silenciosamente; mesmo assim o modo continua entregando condutas imperativas e sem proveniência.

Ação: Trocar fallback de recomendação por aviso explícito de indisponibilidade clínica, preservando apenas dados de referência e resultados previamente validados, ou validar formalmente uma engine offline completa.

F03 — Fenoconversão de comedicações não chega à via online [P0 / clínico]

Constatação: fetchGsiEvaluation recebe comedications, mas o body POST contém apenas {genotypes,sources}. Assim, os inibidores marcados no frontend não integram a requisição/geração de chave do cache. O código local só aplica três inibidores de CYP2D6.

Ação: Definir contrato farmacogenômico explícito para DDI/fenoconversão; enviar o contexto necessário, versionar regras e gerar cenários comparativos com e sem inibidor.

F04 — Interpretação HLA genérica sem droga [P0 / clínico]

Constatação: computeLocalPhenotype marca qualquer HLA com asterisco como Positive (High Risk), sem distinguir HLA-B*57:01/abacavir, HLA-B*58:01/alopurinol e HLA-B*15:02/carbamazepina.

Ação: Separar genótipo HLA da indicação medicamento-específica; impedir agregação de "HLA positivo" como contraindicação genérica.

F05 — Critérios de severidade são textuais [P1 / clínico]

Constatação: renderResultsView escolhe danger quando descrição contém "evitar" ou "contraindicação". Mensagens em inglês ou outras expressões de alta gravidade tornam-se warning. Ao selecionar aba DPWG, a descrição principal prioriza CPIC quando presente.

Ação: Usar categorias estruturadas da fonte, preservando consórcio, recomendação, evidência, força, contexto clínico e idioma. A aba deve exibir a fonte selecionada.

F06 — Dados genéticos circulam na URL/localStorage [P1 / privacidade]

Constatação: O compartilhamento usa ?q=JSON percent-encoded (~1925), expondo genótipos a histórico, logs e compartilhamentos; localStorage guarda painel genético em texto. Ambos são incompatíveis com a alegação de prontuário seguro para dados reais.

Ação: Não transmitir genótipos em query string. Usar identificação efêmera com acesso autenticado, expiração, revogação e minimização; definir retenção e controles de navegador.

F07 — Origin/Referer não é autenticação [P1 / segurança]

Constatação: /api/gsi permite requisições sem token que declarem origem autorizada. Cabeçalhos podem ser falsificados por clientes não-browser. A quota por IP não substitui identidade institucional, nem protege pacientes.

Ação: Para uso clínico, adotar OAuth/OIDC e autorização por usuário/tenant; segregar token de parceiros e implementar verificação de identidade, escopo e trilha de auditoria.

F08 — Uso de innerHTML com campos da API [P1 / segurança]

Constatação: A UI insere drugKey, descrição, genótipos, nome de diretriz e fenótipo em innerHTML (linhas ~1564 e ~1622–1640). É uma superfície de XSS se dados externos ou cache forem contaminados.

Ação: Renderizar com textContent ou escaping/sanitização forte, CSP rigorosa e testes de payload hostil.

F09 — Retenção do cache indefinida [P1 / privacidade]

Constatação: expires_at impede HIT após 24 horas, mas não há rotina de purge no banco. genotype_payload contém alelos originais e response_payload pode conter análise clínica; não foi apresentado plano de retenção/descarte.

Ação: Implementar exclusão verificável por política de retenção, controles de propósito, minimização de payload e trilha auditável.

F10 — Testes automatizados não atestam paridade [P1 / qualidade]

Constatação: scripts/test_scenarios.js depende de CDP localhost:9222, lê clinpgx/prototipo/prototype-clinpgx.html embora o repo use prototipo/, procura evaluateClinPgxSystem e imprime "Todos passaram" sem assertivas de resultado. A suíte está desatualizada.

Ação: Criar testes determinísticos com assertivas, fixtures CPIC/DPWG/FDA versionadas, CI obrigatória e testes de regressão por cenário com laudos médicos.

F11 — FHIR/CDS Hooks declarados além do implementado [P1 / interoperabilidade]

Constatação: Exportação cria Bundle type=transaction com Observation sem entry.request.method/url. Não há endpoints de descoberta CDS Hooks, hook context, cardinalidades e validação formal.

Ação: Ajustar recursos aos perfis HL7 Genomics IG e validar com validator oficial; não anunciar compatibilidade EHR/CDS Hooks antes de prova de interoperabilidade.

F12 — Escopo de catálogo e documentação divergem [P1 / transparência]

Constatação: O HTML exibe "141 Medicamentos Catalogados" na enciclopédia, mas ENCYCLOPEDIA_CATALOG contém 23 entradas agrupadas em 6 categorias; múltiplas entradas agregam nomes de drogas. A API remota pode retornar mais dados em outros fluxos.

Ação: Distinguir cobertura da API remota da cobertura efetiva da enciclopédia e dos alertas locais; publicar tabela gene-droga-versionamento verificável.

F13 — Bases de pacientes não coincidem [P2 / integridade]

Constatação: Frontend e Supabase usam identificadores diferentes para Sr. João (PAC-89211 vs PAC-50921) e Ana Clara (PAC-33109 vs PAC-33108); o frontend não lê public.patients.

Ação: Marcar pacientes do frontend como fixtures locais ou harmonizar IDs após especificar a futura persistência; evitar a alegação de prontuário cloud já operacional.

4. Verificação da camada Supabase/Vercel

Controle	Constatação	Leitura do risco
RLS	gsi_cache, patients e gsi_rate_limits com RLS on; anon/auth sem SELECT; service_role com SELECT.	Bom isolamento de acesso direto, mas service_role bypass RLS; backend precisa autorização própria.
Advisors	Supabase informou INFO: RLS sem policy nas três tabelas e índice expires_at ainda não utilizado.	"Sem policy" é intencional para tabelas internas; índice nunca usado isoladamente não é defeito.
Quota	RPC service_role only; limite 30/min por cliente e 1/s de novas chamadas upstream.	Mitiga pico, mas sessões autenticadas e abuso distribuído continuam fora do controle.
Vercel	Commit 0552a512... READY e domínio genx-sand; função iad1 (EUA).	Publicação demonstrada, não SLA, pentest ou homologação de dados clínicos.
Chaves	Service key/token em variáveis protegidas da Vercel; valores não extraídos.	Boas práticas iniciais. Exigir rotação, inventário, menor privilégio e gestão de incidentes.

5. Confrontação científica e limites da evidência

Tema	Referência científica	GenX e risco
CYP2D6/codeína	CPIC opioides: IM AS 0<x<1.25 recebe dose inicial de bula com vigilância, PM/UM evitar.	Cortes de CYP2D6 básicos se alinham; generalizações do fallback e alegações de "dose sempre evitar" requerem contexto.
CYP2C19/clopidogrel	CPIC 2022 distingue PCI/ACS de indicações neurovasculares e fenótipos com alelos raros.	Fallback ignora *4 como alelo nulo; descrição única para cenários distintos extrapola diretriz.
DPYD/fluoropirimidinas	CPIC recomenda ajuste por atividade 1–1.5, com titulação/monitoramento; deficiência total é crítica.	A regra genérica 50% não é uma validação individual universal; requer forma de aplicação e revisão.
HLA-B	Associação é específica da combinação alelo/fármaco.	"Positive High Risk" para qualquer HLA com * não equivale a uma recomendação PGx.
PREPARE / Lancet	Estudo randomizado, N=6944; 21% vs 28% entre pacientes com variante acionável após 12 semanas (OR 0,70).	A redução relativa de ~30% é achado populacional em condições específicas; não valida o GENX nem implica 30% em todos.

Nível de confiança: alto para divergências diretamente demonstradas no código e metadados; médio para risco regulatório, que depende de finalidade pretendida e modelo de negócio; indeterminado para concordância clínica percentual, desempenho prospectivo e paridade completa PharmDOG, pois faltam amostras versionadas, execução independente do motor e revisão clínica externa.

6. LGPD, HIPAA, Anvisa e CFM

LGPD / ANPD

Dados genéticos e de saúde associados a indivíduo identificável são dados pessoais sensíveis (art. 5º, II da LGPD). Para uso real: mapear controlador/operador, hipótese do art. 11, finalidade, minimização, consentimento quando aplicável (não é a única base), RIPD proporcional ao alto risco, direitos dos titulares, retenção, incidentes, contratos com fornecedores e transferência internacional. O processamento em Vercel iad1 e ClinPGx externo exige análise e salvaguardas segundo Resolução ANPD 19/2024; região brasileira do Supabase não elimina esse fluxo.

HIPAA (Estados Unidos)

HIPAA não se aplica automaticamente a qualquer aplicativo de saúde brasileiro. Aplica-se a covered entities e business associates nas condições da norma. Se GENX prestar serviço a entidade coberta nos EUA tratando PHI, deve avaliar BAA com provedores de nuvem, segurança, logs, acessos e análise de risco. Nenhuma BAA ou evidência equivalente foi apresentada.

SaMD / Anvisa

O dossiê REA conclui uso clínico imediato e licitude plena sem demonstrar regularização; essa conclusão não é sustentada. A RDC 657/2022 define SaMD pela finalidade médica, incluindo SaaS. A RDC 751/2022 rege classificação de risco e regularização. A classificação exata do GENX depende de intended use, criticidade de decisões farmacológicas e público-alvo e deve ser formalizada com especialista regulatório/Anvisa. "O médico decide" e um disclaimer não dispensam exigências. Normas de ciclo de vida, risco, usabilidade e validação merecem plano documentado.

CFM

Resolução CFM 2.454/2026 disciplina IA na medicina desde agosto/2026. Se o GENX for qualificado como sistema/aplicação de IA no sentido da norma, suas exigências de transparência, validação, supervisão e privacidade são relevantes; um motor puramente determinístico de regras não é automaticamente IA. A responsabilidade profissional do médico e o dever de sigilo subsistem independentemente da classificação.

Licenciamento ClinPGx e propriedade intelectual

ClinPGx/PharmGKB informam CC BY-SA 4.0 para dados, mas condicionam o acesso à Data Usage Policy; nota oficial de 2018 menciona restrição à venda de dados como item comercial. CC BY-SA não equivale a permissão irrestrita para revenda de banco, uso de marca, cópia de interface ou exploração clínica. A alegação do dossiê de plena liberdade comercial é excessiva. Obter análise jurídica específica e contato com api@clinpgx.org antes de serviço comercial, verificando versões e terceiros.

7. Divergências relevantes nos dossiês REA

Afirmação dos laudos	Evidência auditada	Parecer
"Paridade funcional 100%"	23 cards na enciclopédia; 5 genes com score offline; teste sem assertivas; FHIR incompleto.	Não comprovada.
"Auth Supabase, prontuário hospitalar seguro"	patients não usado pelo frontend; sem fluxo de identidade/autorizações reais.	Incorreta para dados reais.
"Disponibilidade 100%/99,99% e imunidade a falhas"	Dependência de API externa, quota, fallback muito incompleto; nenhum SLA examinado.	Não comprovada.
"FHIR/CDS Hooks interoperável"	Bundle transaction estruturalmente incompleto e ausência de serviços CDS Hooks.	Não conforme alegado.
"Uso imediato seguro por médicos"	Faltam validação clínica, regularização, gestão de risco e segurança de usuários.	Não recomendado.
"Redução de RAMs PREPARE aplicável"	Estudo independente; resultado entre grupo acionável, em população e período específicos.	Não atribuir eficácia clínica ao GENX.

8. Plano de correção prioritário sob Feature Freeze

Prioridade	Objetivo e entregáveis	Gate de aceitação
G0 - imediato	Suspender alegações clínicas de 100% e utilização com pacientes reais; preservar commit e dataset do release; só dados fictícios.	Interface/README sinalizam protótipo de pesquisa sem recomendações clínicas certificadas.
G1 - segurança	Remover exposição de genótipo em URLs; projetar IAM/RBAC por paciente/tenant; controle de XSS; logs sanitizados, retenção e DPIA/RIPD.	Pentest, testes de autorização negativos, auditoria de retenção e rastreabilidade.
G2 - clínica	Corrigir fail-safe de alelos não mapeados; HLA por fármaco; fenoconversão online; retirada da falsa equivalência offline; diretrizes versionadas.	Matriz de casos positivos/negativos, assinada por especialista em PGx, sem falso-negativos críticos.
G3 - qualidade	Reescrever suíte automatizada e CI; fixtures de CPIC/DPWG/FDA; validação de transações FHIR, perfil Genomics e hooks.	Testes reproduzíveis, cobertura demonstrada e evidências de conformidade HL7.
G4 - jurídico	Documento de finalidade pretendida, análise de risco SaMD, estratégia de regularização, política de dados ClinPGx, contratos e parecer HIPAA condicional.	Parecer regulatório e de PI formal, com responsável técnico designado.
G5 - novo piloto	Somente após gates: piloto supervisionado com dados devidamente autorizados e rastreáveis.	Validação clínica externa, documentação e decisão formal de go/no-go.

Feature Freeze: não abrir funcionalidades. Ajustes P0/P1 devem ser classificados como correções de segurança/conformidade sujeitas a autorização e revisão; não foram implementados nesta auditoria.

9. Fontes verificáveis e trilha de evidência

Código: frontend: https://github.com/boiverde/genx/blob/main/prototipo/prototype-clinpgx.html
Código: proxy GSI: https://github.com/boiverde/genx/blob/main/api/gsi.js
Código: testes: https://github.com/boiverde/genx/blob/main/scripts/test_scenarios.js
Dossiê legal (HTML do PDF): https://github.com/boiverde/genx/blob/main/docs/DOSSIE_LEGAL_E_CLINICO_CLINPGX.html
Manifesto clínico (HTML do PDF): https://github.com/boiverde/genx/blob/main/docs/MANIFESTO_IMPACTO_E_USO_CLINICO.html
Plano e relatório REA: https://github.com/boiverde/genx/blob/main/CLINPGX_PLANO_REA.md
RDC 657/2022 Anvisa: https://anvisalegis.datalegis.net/action/ActionDatalegis.php?acao=abrirTextoAto&numeroAto=00000657&orgao=RDC%2FDC%2FANVISA%2FMS&tipo=RDC&valorAno=2022
RDC 751/2022 Anvisa: https://anvisalegis.datalegis.net/action/ActionDatalegis.php?acao=abrirTextoAto&numeroAto=00000751&orgao=RDC%2FDC%2FANVISA%2FMS&tipo=RDC&valorAno=2022
ANPD: RIPD: https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/relatorio-de-impacto-a-protecao-de-dados-pessoais-ripd
ANPD: transferência internacional: https://www.gov.br/anpd/pt-br/assuntos/assuntos-internacionais/transferencia-internacional-de-dados
HIPAA HHS Cloud Guidance: https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing/index.html
CFM Resolução 2454/2026: https://sistemas.cfm.org.br/normas/arquivos/resolucoes/BR/2026/2454_2026.pdf
CPIC opioides: https://pmc.ncbi.nlm.nih.gov/articles/PMC8249478/
CPIC clopidogrel 2022: https://pmc.ncbi.nlm.nih.gov/articles/PMC9287492/
CPIC DPYD fluoropirimidinas: https://pmc.ncbi.nlm.nih.gov/articles/PMC5760397/
PREPARE (síntese publicada): https://pmc.ncbi.nlm.nih.gov/articles/PMC10213803/
FHIR Bundle: transaction: https://fhir.hl7.org/fhir/bundle-definitions.html
HL7 Genomics IG: https://hl7.org/fhir/uv/genomics-reporting/
CDS Hooks v2: https://cds-hooks.hl7.org/
ClinPGx API Terms: https://api.clinpgx.org/
Licença PharmGKB / ClinPGx: https://blog.clinpgx.org/changes-to-pharmgkb-data-licensing/

Nota: documento de auditoria técnica e triagem regulatória. Não constitui parecer jurídico, validação clínica certificada, laudo de penetração nem autorização da Anvisa. Código/contas permaneceram em somente leitura.